NEXUS FINANCIAL SERVICES

INFORMATION SECURITY POLICY FRAMEWORK

Document Hierarchy, Policy Governance, and Information Security Policy

Prepared by	ANGELA AMUZU CHRISTY AGHE JOEL KAMANDA MAUREEN UZOEWULU OLATUNJI AFOLAYAN OREOLUWA LAWAL
Prepared for	Board of Directors and Executive Management, Nexus Financial Services
Date	October 17, 2026

Table of Contents

1. Executive Summary 4
2. Background and Approach 5
1.1 The Business Problem 5
1.2 Regulatory Context 5
3. Part A: Build the Framework 6
3.1 Nexus Documentation Hierarchy 6
3.2 Mapping Nexus' problems to the documentation layers 8
3.3 The Four Core Policies 9
3.4 How the Core Policies Connect 10
3.5 Policy Lifecycle at Nexus 11
4. Part B: Define Governance 12
1.3 How the Governance Requirements Work 12
4.1 Governance Matrix 13
4.2 Common Governance Rules For All Policies 15
5. PART C: Information Security Policy 16
5.1 Version Control 16
5.2 Document Control 17
5.3 Purpose 17

5.4 Scope 18
5.5 Objectives 18
5.6 Roles and Responsibilities 19
5.7 Risk Management 19
5.8 Information Protection 20
5.9 Access Control 21
5.10 Incident Management 21
5.11 Third Parties 22
5.12 Awareness and Training 22
5.13 Compliance 23
5.14 Enforcement 23
5.15 Exceptions 23
5.16 Policy Review and Maintenance 24
6. Conclusion 24
7. References 25

1. Executive Summary

Nexus Financial Services is a growing financial services company headquartered in Lagos, Nigeria, with 150 employees, $800M in assets, cloud-based applications, remote staff and payment systems. Nexus already has security documents, but no consistent framework governs them. Several policies are outdated, many have no clear owner or review schedule, departments and technical teams follow their own security practices, and data classification, access practices and staff training are inconsistent. The underlying problem is not a lack of controls; it is a lack of consistent governance.

This report sets out a framework to fix that:

1. **Part A: Build the Framework**. A five-layer documentation hierarchy (Policy, Standard, Procedure, Guideline, Baseline) that lists the documents Nexus needs at each level, organized around four core policies: Information Security, Acceptable Use, Access Control and Data Classification.
2. **Part B: Define Governance**. A governance matrix that names the owner, reviewer, approver, review frequency, version control, training requirements, enforcement mechanism and exception process for each core policy.
3. **Part C: Write the ISP**. A Board-ready Information Security Policy covering purpose, scope, objectives, roles and responsibilities, risk management, information protection, access control, incident management, third parties, awareness, compliance, enforcement, exceptions and review.

2. Background and Approach

1.1 The Business Problem

Inconsistent security governance weakens Nexus's cybersecurity posture and its readiness for compliance. The problem has three measurable parts:

a. Outdated policies with no owner and no review schedule
b. Departments and technical teams follow their own security practices
c. Inconsistent data classification, access practices, and staff training

1.2 Regulatory Context

As a financial services firm that processes personal and payment data in Nigeria, Nexus must align its framework with the Nigeria Data Protection Act (NDPA) 2023, the Central Bank of Nigeria (CBN) cybersecurity requirements that apply to its license category, and the Payment Card Industry Data Security Standard (PCI DSS) wherever it handles card data. ISO/IEC 27001:2022 is used as the reference for good practice in managing information security.

3. Part A: Build the Framework

Nexus's framework uses a five-layer hierarchy. The **policy** sets management direction, the **standard** sets mandatory requirements, the **procedure** gives the steps, the **guideline** gives recommended practice, and the **baseline** sets the minimum configuration. The layers support each other, so every requirement can be traced from Board direction down to evidence.

3.1 Nexus Documentation Hierarchy

Layer	Purpose	Approved by	What should exist
Policy	Management direction: What must Nexus achieve?	Board / Executive Committee	• Information Security Policy • Acceptable Use Policy • Access Control Policy • Data Classification Policy • Incident Management • Third-Party Risk • Business Continuity • Privacy / Data Protection
Standard	Mandatory requirements: What specific rules must be met?	CISO	• Authentication and Password Standard (aligned with NIST SP 800-63B) • Privileged Access Management Standard • Data Handling and Labeling Standard • Encryption and Key Management Standard • Logging and Monitoring Standard • Vulnerability and Patch Management Standard

			• Third-Party Security Standard • Payment Systems Security Standard (PCI DSS aligned) • Cloud Security Standard
Procedure	Step-by-step process: How is the requirement performed?	Process owner, with CISO sign-off	• Joiner-Mover-Leaver (JML) and Access Request • Quarterly User Access Review • Incident Response and Breach Notification • Risk Assessment and Risk Register • Policy Lifecycle and Document Control • Exception Management • Vendor Onboarding and Due Diligence • Security Training and Attestation • Secure Data Disposal
Guideline	Recommended practice: What is the recommended approach?	CISO / GRC	• Secure Remote and Home Working • Recognizing Phishing and Social Engineering • Passphrase Creation • Clean Desk and Clear Screen • Safe Use of Messaging and Generative AI Tools
Baseline	Minimum configuration: What minimum security condition must exist?	Head of IT, with CISO sign-off	• Windows / macOS Endpoint Baseline (screen lock, disk encryption, EDR) • Mobile Device Baseline

			• Cloud Tenant Baseline (e.g., Microsoft 365, AWS) • Server and Database Baseline • Network and Firewall Baseline • Payment System Baseline

3.2 Mapping Nexus' problems to the documentation layers

Identified Problem	Relevant Layer	Application
Policies are outdated, have no clear owner, and lack a review schedule	Policy	Establish policy governance requirements for document ownership, approval, version control and scheduled reviews
Departments and technical teams follow their own security practices	Policy and Standard	Establish common security expectations through policies and define consistent, mandatory requirements through standards
Data classification is inconsistent	Policy, Standard and Procedure	Establish a Data Classification Policy, define classification and handling requirements in a standard, and document the steps for classifying and handling information in a procedure.
Access practices are inconsistent	Standard and Procedure	Define consistent access requirements in an Access Control Standard and document the steps

		for requesting, approving, reviewing and revoking access
Staff security training is inconsistent	Policy and Guidance	Establish mandatory security awareness requirements through policy and provide practical guidance to help employees follow security practices

3.3 The Four Core Policies

Based on Nexus Financial Services' identified gaps, the following four core policies should establish consistent security expectations, clarify responsibilities and support compliance readiness. Together, these policies address Nexus' main governance and security weaknesses:

- Information Security establishes the overall direction and accountability.
- Acceptable Use sets clear expectations for employee behaviour.
- Access Control promotes consistent and authorized access to information and systems.
- Data Classification ensures information receives appropriate protection based on its sensitivity.

These policies will be supported by documented standards, procedures and guidelines. Each policy would also have an assigned owner, reviewer, approver, review frequency, version control, training requirements, enforcement mechanism and exception process.

Policy	What it does	Problem Addressed at Nexus
Information Security Policy (ISP)	The umbrella policy. Establishes the overall security governance framework, responsibilities, and requirements for protecting company and customer information.	Outdated policies, unclear ownership, and inconsistent security practices across departments
Acceptable Use Policy (AUP)	Turns the ISP into expected employee behaviour when using Nexus resources.	Different security practices across departments and the need for consistent employee expectations
Access Control Policy (ACP)	Establishes requirements for granting, reviewing, modifying, and revoking access based on business needs and least privilege.	Inconsistent access practices across departments and technical teams
Data Classification Policy (DCP)	Defines how information is categorized by sensitivity.	Inconsistent data classification and information-handling practices

3.4 How the Core Policies Connect

Using the example of an employee handling customer financial information, the **Data Classification Policy** says how sensitive it is, the **Access Control Policy** says who may access it, the **Acceptable Use Policy** says how it may be used, and the **Information Security Policy** provides the overall governance. Standards, procedures, guidelines and baselines then supply the detail.

3.5 Policy Lifecycle at Nexus

Stage	How Nexus applies it
Identify	Record the driver: business risk, regulation (NDPA, CBN), audit finding, incident, new technology, contract or management requirement.
Develop	The owner drafts the document and defines scope, stakeholders, requirements and supporting documents before writing.
Review	Reviewers (Legal / DPO, IT, HR, business owners, Internal Audit) assess accuracy, practicality and compliance
Approve	The approver named in the governance matrix formally approves it, and the approval is minuted.
Publish	Publish the approved PDF read-only on the intranet policy portal, and update the register.
Train and communicate	HR and GRC deliver training; staff complete electronic attestation.
Implement	Implement supporting standards, procedures, baselines, and deploy controls.
Monitor and enforce	Measure compliance through KPIs, audits, and technical monitoring, and address violations.
Review and update	Annual review, or sooner after a major change, incident, new regulation, or audit finding.
Retire	Obsolete versions are withdrawn, archived for 7 years, and marked superseded in the register.

4. Part B: Define Governance

Nexus Financial Services needs a consistent governance process to ensure each policy has clear accountability, remains current, and is applied across the organization.

1.3 How the Governance Requirements Work

- **Owner:** Maintains the policy and ensures it remains relevant and effective.
- **Reviewer:** Checks the policy for accuracy, completeness, risk implications, and alignment with business and compliance requirements.
- **Approver:** Formally authorizes the policy before it takes effect.
- **Review frequency:** Establishes when the policy must be reassessed, with additional reviews triggered by significant changes or incidents.
- **Version control:** Ensures employees can identify the current approved policy and that previous versions remain traceable.
- **Training requirements:** Ensure relevant employees understand their responsibilities and know how to follow the policy.
- **Enforcement mechanism:** Defines how violations are investigated and addressed consistently.
- Exception process: Allows justified deviations only through documented risk assessment, appropriate approval and periodic review.

4.1 Governance Matrix

Governance Requirement	Information Security Policy	Acceptable Use Policy	Access Control Policy	Data Classification Policy
Owner	Chief Information Security Officer (CISO)	CISO (HR as co-sponsor for staff conduct)	CISO (Head of IT implements)	Data Protection Officer (DPO)
Reviewer	GRC Manager, Legal and Compliance, DPO, Head of IT, Chief Risk Officer; Internal Audit for assurance	Head of HR, Legal, Head of IT, GRC Manager, employee representatives	Head of IT, GRC Manager, business system owners, Internal Audit	CISO, Legal and Compliance, GRC Manager, Heads of Finance and Operations (data owners)
Approver	Board of Directors, via the Board Risk Committee	Chief Executive Officer / Executive Committee	Executive Committee (endorsed by the Board Risk Committee)	Executive Committee (endorsed by the Board Risk Committee)
Review Frequency	Annually, plus after major incidents, regulatory change, a merger, or a new business line	Annually, plus when new technology is introduced (e.g., AI tools, BYOD)	Annually; access reviews quarterly (privileged accounts monthly)	Annually; asset classification confirmed by data owners every 6 months

Version Control	Unique document ID, version number, approval date, effective date and revision history	Unique document ID, version number, approval date, effective date and revision history	Unique document ID, version number, approval date, effective date and revision history	Unique document ID, version number, approval date, effective date and revision history
Training Requirements	All staff and contractors at onboarding (within 30 days) and annually; Board and executive cyber briefing yearly	Onboarding acknowledgment before system access; annual re-attestation; quarterly phishing simulations	Role-based training for managers (approvals), system administrators (Privileged Access Management) and service desk (identity checks)	All staff: labeling and handling; data owners: classification and retention duties
Enforcement Mechanism	Quarterly KPI and KRI reports to the Board; Internal Audit reviews; disciplinary process; contract remedies for third parties	Data loss prevention, web filtering, device management, email monitoring; HR disciplinary action	Identity and access management workflow, MFA enforcement, PAM vault, SIEM alerts, review sign-off	Labeling tools, Data Loss Prevention (DLP) rules tied to labels, encryption, spot checks by GRC
Exception Process	Documented justification, risk	Written request,	Documented request, system-owner review,	Documented justification, data-

	assessment, authorized approval and expiry date	Business justification, risk review and time-limited approval	Security assessment and Authorized approval	owner review, safeguards and time-limited approval

4.2 Common Governance Rules For All Policies

To avoid repeating the same administrative requirements across different documents, Nexus should establish the following organization-wide rules:

1. ***Central policy register:*** GRC maintains a register containing each policy's owner, approver, version, status and next review date.
2. ***Annual review cycle:*** All four policies are reviewed at least annually, with earlier reviews when significant changes occur.
3. ***Controlled approval:*** Policies must be approved by the designated authority before publication.
4. ***Training and communication:*** Relevant personnel receive policy communications and complete required training, with completion records maintained.
5. ***Documented exceptions:*** Exceptions must have an authorized risk owner, appropriate approval, compensating controls where needed, and a defined expiry date.
6. ***Consistent enforcement:*** Violations are documented, investigated, and addressed under approved company procedures and applicable law.

5. PART C: Information Security Policy

5.1 Version Control

Version	Author	Comments	Date
0.1	ANGELA AMUZU CHRISTY AGHE JOEL KAMANDA MAUREEN UZOEWULU OLATUNJI AFOLAYAN OREOLUWA LAWAL	Initial draft for stakeholder review	October 17, 2026
0.2	GRC Manager		To be completed
1.0	CISO		On approval

5.2 Document Control

Document ID	NFS-ISP-001
Audience	All Nexus employees, contractors, interns, temporary staff, and third parties with access to Nexus information or systems
Document Owner	CISO
Approved By	Board of Directors, via the Board Risk Committee
Classification	Internal
Status	Draft for Board approval
Effective Date	Date of Board approval
Review Process	Reviewed by the Policy Owner at least annually, and earlier after a major incident, a significant regulatory or business change, or an audit finding. Reviewers: GRC Manager, Legal and Compliance, DPO, Head of IT, Chief Risk Officer.
Next Review Date	12 months from the effective date (tracked in the Policy Register)

5.3 Purpose

This policy sets the overall direction for information security at Nexus Financial Services. It protects the confidentiality, integrity and availability of customer, financial, employee and business information, and it supports Nexus's business objectives, regulatory obligations and customer trust. It is the single source of authority for all information security standards, procedures, guidelines and baselines at Nexus. No department may issue security requirements that conflict with it.

5.4 Scope

This policy applies to:

- All employees, contractors, interns, temporary staff and third parties, whether they work on-site, remotely or while traveling.
- All information Nexus owns or processes, in any form (electronic, paper or verbal), including customer and payment data.
- All systems, networks, cloud-based applications, payment systems, endpoints, mobile devices and physical locations used to store, process or transmit Nexus information.

5.5 Objectives

Nexus aims to:

- Protect customer and financial information from unauthorized access, disclosure, alteration and loss.
- Establish consistent security practices across departments.
- Comply with applicable laws, regulations and contracts, including the NDPA 2023, the Central Bank of Nigeria (CBN) cybersecurity requirements that apply to Nexus's license category, and PCI DSS for card data.
- Assign clear ownership and accountability for information security.
- Detect, respond to, and recover from security incidents quickly, with minimal impact on customers.
- Build a security-aware culture through regular, measurable training.

5.6 Roles and Responsibilities

Role	Responsibility
Board of Directors (Board Risk Committee)	Approves this policy and the risk appetite; oversees cybersecurity risk; receives quarterly reports on security status, incidents, risks, and audit results.
Chief Executive Officer / Executive Committee	Provides resources; approves supporting policies; holds department heads accountable for compliance.
Chief Information Security Officer (CISO)	Owns this policy and the security framework; issues standards; approves exceptions; leads incident response; reports to the Board.
GRC Manager / GRC Analysts	Maintain the Policy Register and Exception Register; coordinate reviews; track compliance and KPIs; maintain audit evidence.
Data Protection Officer (DPO)	Owns the Data Classification Policy; advises on NDPA obligations; leads personal-data breach notification.
Employees and contractors	Follow policies, complete required training and report suspected incidents.
Third-party providers	Comply with applicable contractual security requirements and incident-reporting obligations.

5.7 Risk Management

- Nexus maintains a documented information security risk methodology aligned with ISO/IEC 27001:2022, covering risk criteria, likelihood and impact scoring, and acceptance thresholds.
- A formal risk assessment is carried out at least once a year and whenever significant changes occur (new technology, new vendors, mergers or major incidents).

- All risks are recorded in a single enterprise risk register with a named risk owner, a treatment decision (mitigate, transfer, avoid or accept) and a target date.
- Residual risk above the risk appetite must be accepted by the Executive Committee or, for critical risks, the Board Risk Committee.

5.8 Information Protection

Nexus shall protect information according to its sensitivity, business value and applicable legal, regulatory and contractual requirements.

- All information must be classified as Public, Internal, Confidential or Restricted, in line with the Data Classification Policy.
- Classification determines how information is accessed, stored, shared, transmitted, retained and disposed of.
- Apply appropriate safeguards to customer information, payment records and other confidential data.
- Personal data must be processed lawfully, kept to the minimum necessary, and retained only as long as required.
- Report suspected unauthorized disclosure, loss, or mishandling promptly.
- All critical information assets must be recorded in an asset register with an owner and a classification.
- Backups of critical systems must be taken, protected, and tested regularly.

5.9 Access Control

Access to Nexus information and systems shall be authorized, limited to business needs, and reviewed periodically.

- Access is granted based on least privilege, need-to-know, and role-based access control, with segregation of duties for critical financial processes.
- Every user has a unique identity. Shared accounts are prohibited unless an approved exception exists.
- Multi-factor authentication is mandatory for remote access, cloud applications, payment systems, and all privileged accounts.
- Access follows the Joiner-Mover-Leaver procedure. Leaver access is removed within 24 hours, or immediately for dismissals.
- Access is reviewed quarterly (privileged access monthly), and accounts dormant for 90 days are disabled.
- Detailed requirements are in the Access Control Policy, the Authentication Standard, and the Privileged Access Management Standard.

The Access Control Policy and supporting procedures like the Authentication Standard and the Privileged Access Management Standard shall define detailed implementation requirements.

5.10 Incident Management

- All staff must report suspected security incidents, phishing or data loss to the IT Security team immediately, and no later than 1 hour after discovery.
- Nexus maintains a tested Incident Response Procedure covering detection, triage, containment, eradication, recovery and lessons learned.

- Personal data breaches are assessed by the DPO and, where required, reported to the Nigeria Data Protection Commission within 72 hours, with affected individuals informed without undue delay when there is high risk.
- Where Nexus's license makes it subject to the CBN framework, cyber incidents are reported to the CBN within 24 hours.
- Incident response is tested at least once a year through a tabletop exercise.

5.11 Third Parties

- Vendors, cloud providers and payment partners are risk-assessed before onboarding and reassessed at least annually, based on how critical they are.
- Contracts must include security, confidentiality, data protection, breach notification, right-to-audit and exit clauses.
- Third-party access must be approved, time-limited, protected with MFA and monitored. Third parties sign an NDA and an access agreement before receiving access.
- Transfers of personal data outside Nigeria must meet NDPA requirements.

5.12 Awareness and Training

- All staff and contractors complete security awareness training within 30 days of joining and every year after that, and they acknowledge this policy and the Acceptable Use Policy.
- Role-based training is required for system administrators, developers, managers who approve access, finance and payment teams, and the service desk.
- Phishing simulations are run quarterly, and results are reported to management.
- Training completion is tracked, with a target of at least 95%. Staff with overdue training may have their access suspended.
- Nexus shall maintain training records, monitor completion, and follow up on outstanding requirements.

5.13 Compliance

- Nexus identifies and maintains a register of applicable legal, regulatory, and contractual requirements.
- Compliance is monitored through KPIs and KRIs, technical scans, internal audits, and annual control self-assessments.
- The CISO reports security posture, incidents, risks, exceptions, and audit findings to the Board Risk Committee every quarter.
- Evidence of controls (approvals, reviews, logs, and configuration reports) is retained to support audits.

5.14 Enforcement

- Compliance with this policy is mandatory. Non-compliance may result in:
- Suspension or revocation of system access.
- Disciplinary action under the HR policy, up to and including termination of employment or contract.
- Contract penalties or termination for third parties.
- Legal action or referral to authorities where laws are broken.

5.15 Exceptions

No exceptions are permitted to this policy itself. Exceptions to supporting standards or baselines must be documented, amd each one requires:

- a business justification,
- a risk assessment,
- compensating controls,
- approval by the CISO, and
- acceptance by the risk owner.

Exceptions are time-limited (6 months at most), recorded in the Exception Register, and reported quarterly.

5.16 Policy Review and Maintenance

The CISO will review this policy at least once a year, and earlier when significant changes occur in the business, technology, threats, or regulations, or after a major incident or audit finding. Reviews are coordinated by GRC and recorded in the Policy Register with a new version number. Any change to requirements requires Board approval. Obsolete versions are formally withdrawn and archived.

6. Conclusion

Nexus's security weaknesses come from missing governance, not missing documents. A five-layer framework with four core policies, clear ownership and a Board-approved Information Security Policy gives Nexus one consistent, enforceable and auditable approach to security. Approving the ISP and the Policy Register is the first and most important step.

7. References

1. 10Alytics. (2025). *10Alytics access control policy* (Version 2.2).
2. Bello-Abubakar, A. (n.d.). *Enterprise policy, standards and procedures* [Lecture slides]. 10Alytics.
3. Central Bank of Nigeria. (2024). Risk-Based Cybersecurity Framework and Guidelines for Deposit Money Banks and Payment Service Banks. https://www.cbn.gov.ng/Out/2024/BSD/CBN%20Risk-Based%20Cybersecurity%20Framework%20for%20DMBs%20and%20PSBs_2024.pdf
4. Federal Republic of Nigeria. (2023). Nigeria Data Protection Act, 2023 (Act No. 37). https://ndpc.gov.ng/wp-content/uploads/2024/03/Nigeria_Data_Protection_Act_2023.pdf
5. Nigeria Data Protection Commission. (n.d.). Frequently Asked Questions. https://ndpc.gov.ng/faqs/
6. International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection: Information security management systems: Requirements. https://www.iso.org/standard/27001
7. PCI Security Standards Council. (n.d.). PCI DSS Document Library. https://www.pcisecuritystandards.org/document_library/
8. National Institute of Standards and Technology. (2017). SP 800-63B Digital Identity Guidelines: Authentication and Lifecycle Management. https://pages.nist.gov/800-63-3/sp800-63b.html